

UNISENAI
Tecnologia em Análise e Desenvolvimento de Sistemas

Arthur Moreira
Douglas do Carmo
Jamil Cherem

SMARTRENT B2B — MATRIZ DE RISCOS

Identificação, probabilidade, impacto e mitigação dos principais riscos do MVP

Florianópolis
2026

1 METODOLOGIA

Cada risco é classificado por probabilidade (baixa, média ou alta) e por impacto (baixo, médio ou alto) sobre o prazo, a qualidade ou o escopo do MVP de 30 dias. A severidade combina as duas dimensões e ordena a atenção da equipe: quanto maior a ênfase tipográfica no quadro a seguir, maior a severidade.

2 REGISTRO DE RISCOS

Quadro 1 – Registro de riscos do projeto

ID	Risco	Prob.	Impacto	Sever.	Mitigação
R01	Indisponibilidade ou instabilidade da Groq API durante o desenvolvimento ou em produção.	Média	Médio	Média	O cálculo de contingência já é requisito obrigatório (RF09), com a origem de cada sugestão registrada; o sistema nunca fica sem um valor sugerido.
R02	Falha na verificação de conflito de datas permitir reservas sobrepostas, o risco mais crítico do domínio de negócio.	Baixa	Alto	Média	Verificação na camada de aplicação, reforçada por controle de concorrência otimista; cobertura de testes dedicada a todos os casos de sobreposição.
R03	Instabilidade ou limite do plano gratuito do Supabase afetar a disponibilidade durante a apresentação à banca.	Média	Médio	Média	Ambiente validado com antecedência; manutenção de uma cópia local do esquema e dos dados de demonstração.
R04	Aumento do escopo pressionar o cronograma de 30 dias.	Alta	Médio	Alta	O protocolo do projeto já classifica qualquer pedido fora da matriz MoSCoW acordada como Visão Futura, preservando o cronograma.
R05	Bloqueios inesperados no ambiente de desenvolvimento local, como já ocorreu com a ausência do Maven e do wrapper, e com a reescrita indevida de pacotes por uma extensão de IDE.	Alta	Baixo	Média	Uso do Maven Wrapper versionado no repositório; documentação viva (STATUS_PROJETO.md e ADRs) registra cada incidente e sua resolução.
R06	Falta de rastreabilidade entre requisitos, código e testes dificultar a arguição da banca.	Média	Médio	Média	Matriz de rastreabilidade de requisitos mantida atualizada a cada entrega.
R07	Cobertura insuficiente de testes automatizados na reta final do prazo.	Média	Alto	Alta	O plano de testes prioriza desde já os casos críticos, conflito de datas e contingência de IA, antes dos casos de borda secundários.

ID	Risco	Prob.	Impacto	Sever.	Mitigação
R08	Falhas expostas durante a demonstração ao vivo para a banca.	Média	Alto	Alta	Ensaio da apresentação com o ambiente já implantado, com antecedência mínima de dois dias, e gravação prévia de um vídeo de segurança da demonstração.
R09	Mídias dos anúncios guardadas em disco local não sobreviverem a uma troca de instância nem escalarem para mais de um servidor.	Média	Médio	Média	O armazenamento está atrás da interface MidiaStorage; migrar para armazenamento de objetos (S3) exige apenas uma nova implementação.
R10	Lembretes de edição esquecida não chegarem por e-mail, hoje apenas registrados em log, e o gestor deixar anúncios fora do ar sem perceber.	Média	Médio	Média	O aviso in-app, o selo de destaque no painel e a contagem de tempo em edição já funcionam; o canal de e-mail é um ponto de extensão (NotificadorEmail) a ser ligado a um SMTP.
R11	O texto do termo de uso, hoje um modelo de trabalho, não ter validade jurídica quando o sistema for usado de verdade.	Média	Alto	Alta	O aceite é versionado e auditado (usuário, imóvel, versão, data, hora e IP); o texto deve ser revisado por assessoria jurídica antes da produção.
R12	Ir à produção com o gateway de pagamento ainda simulado e cobrar ou estornar de forma incorreta.	Média	Alto	Alta	O gateway está atrás da interface GatewayPagamento, com chave de idempotência única no banco para cobrança e estorno; o provedor real é uma nova implementação da interface.
R13	Textos e regras de cancelamento e reembolso entrarem em produção sem a revisão do setor jurídico (o direito de arrependimento está em espera).	Média	Alto	Alta	Textos provisórios centralizados em um único arquivo marcado como pendente; parâmetro CANCEL_REGRET_DAYS desligado e sem efeito; parâmetros da política gravados no snapshot da reserva.
R14	O filtro de conteúdo do SmartChat ocultar texto legítimo ou deixar passar contatos disfarçados.	Média	Médio	Média	Regras e listas configuráveis, dados legítimos da reserva protegidos, mais de cem casos de teste e texto original guardado para revisão futura.
R15	O processamento de vídeo depender do FFmpeg, ausente em ambientes de desenvolvimento, e consumir CPU do servidor.	Média	Médio	Média	Interface VideoProcessingService com fallback básico, tempo máximo e poucas threads por execução, fila com retry; em produção, executar o worker em contêiner com limites.
R16	Limite de envios e agrupamento de notificações do chat em memória não valerem com mais de uma instância do servidor.	Média	Baixo	Baixa	Documentado; trocar por limitador distribuído mantendo a mesma interface.

ID	Risco	Prob.	Impacto	Sever.	Mitigação
R17	A remoção das colunas de WhatsApp apagar dados que alguém ainda precise.	Baixa	Médio	Baixa	Os valores são arquivados em tabelas próprias antes do descarte, em migration separada.
R18	O pedido de exclusão de dados ser usado como rota de fuga em golpe, ou feito por quem invadiu a conta.	Média	Alto	Alta	Nada é excluído automaticamente; análise da equipe com período mínimo, e-mail ao titular com link para cancelar, sinais de risco, restrições temporárias e trava de aprovação por reservas, reembolsos e denúncias.
R19	A execução da exclusão acontecer sem definição do setor jurídico (o que apagar, o que reter).	Média	Alto	Alta	A execução é uma interface sem implementação: concluir recusa e nada é tocado; textos e prazos provisórios em arquivo único, listados como pendentes de revisão.
R20	Avisos de segurança e links de confirmação não chegam ao usuário em produção (e-mail ainda só em log).	Alta	Médio	Alta	Interface EmailSender pronta para SMTP; o corpo (com links) só vai ao log em desenvolvimento (EMAIL_LOG_CORPO); SMTP real registrado como pendência.
R21	Imagem maliciosa ou gigante enviada como foto de perfil (decompression bomb, SVG com script, metadados com localização).	Média	Médio	Média	Tipo real pelos bytes (só PNG e JPEG), limites lidos do cabeçalho antes de decodificar, recodificação em JPEG sem metadados e nome aleatório; original nunca guardado.
R22	Sessões antigas continuarem válidas depois da troca de senha ou de e-mail.	Média	Alto	Alta	Versão de sessão no token (sv): trocar senha ou e-mail invalida os demais tokens.
R23	As restrições temporárias trancarem o usuário legítimo para fora da própria conta.	Baixa	Médio	Baixa	Restrições parciais (login, senha, chat, reembolsos e bloqueio de datas nunca são restritos), cancelamento a qualquer momento, link “não fui eu”, aviso fixo e chave para desligar.
R24	Perda ou vazamento da chave de cifra do SmartChat (SMARTCHAT_CRYPTO_KEY).	Baixa	Alto	Média	Perder a chave torna as mensagens irrecoveráveis: guardá-la em cofre, com backup separado do banco. Vazar a chave junto com o banco anula a proteção. Formato versionado (v1) prepara a rotação, ainda sem rotina.
R25	Golpes e spam no SmartChat (pagamento por fora, contato fora da plataforma, envio em massa).	Média	Alto	Alta	Aviso fixo; alerta ao destinatário e alerta interno sem bloquear; HMAC do texto para detectar envio em massa; limite de envio restrito; e-mail verificado para escrever. Fraude por IA e verificação de identidade ficam para a V2.

ID	Risco	Prob.	Impacto	Sever.	Mitigação
R26	Vazamento de localização por foto (GPS no EXIF) ou por vídeo sem FFmpeg.	Média	Alto	Alta	Fotos recodificadas sem metadados e job para as antigas; vídeo com FFmpeg remove metadados; sem FFmpeg, fora de dev/test, o vídeo é recusado.
R27	Enumeração de conversas e reservas por id sequencial.	Média	Médio	Média	Conversas e mensagens por UUID; reserva, notificação e imóvel de outra pessoa respondem 404 idêntico ao inexistente (id numérico ainda nas rotas: UUID é V2).
R28	Credencial do banco versionada (JAR de entrega com a senha) e ainda presente no histórico do git.	Alta	Alto	Alta	JAR removido e *.jar ignorado; varredura de segredos no CI. Pendente: rotacionar a senha do Supabase e limpar o histórico (roteiro na ADR-008).
R29	Contorno do filtro de contatos (Unicode, caracteres invisíveis, letras espaçadas, números por extenso) e disintermediação.	Alta	Alto	Alta	Normalização NFKC antes dos regex, texto colapsado, números mistos e mensageiros isolados mascarados; alerta para pix e pagamento por fora. Combinar contato sem escrevê-lo exige detecção semântica (V2).
R30	Força bruta no login e criação de contas em massa, com captcha de teste ou segredo padrão do token.	Média	Alto	Alta	Aplicação não sobe com JWT_SECRET ausente/público nem com a chave de teste do reCAPTCHA; limites por e-mail e por IP (rate limit em memória, uma instância).
R31	Dependências desatualizadas com vulnerabilidades conhecidas.	Média	Médio	Média	Spring Boot atualizado para 3.5.16 e Dependabot semanal (Maven, Docker, Actions). Scan completo de CVE no CI fica para a V2.
R32	A telemetria de uso ser tratada como dado pessoal sem base legal ou sem transparência para o usuário.	Média	Alto	Alta	Anônima por desenho (sem usuário, IP, texto digitado nem cookies), respeita Do Not Track e Global Privacy Control, retenção de 180 dias e coleta desligável. Aviso, consentimento e prazo definitivo aguardam o setor jurídico (ADR-009).
R33	Administrador abusar do poder de suspender contas e ler denúncias, ou uma conta de administrador ser comprometida.	Baixa	Alto	Média	Justificativa obrigatória e trilha imutável de cada ação, evidências limitadas às mensagens anexadas (abrir é registrado), proibição de alterar a própria conta ou outro administrador. Aprovação em duas pessoas e níveis de acesso entre administradores ficam para a V2 (ADR-010).

ID	Risco	Prob.	Impacto	Sever.	Mitigação
R34	Suspensão indevida por falso positivo de uma decisão automatizada ou de uma denúncia maliciosa.	Média	Alto	Alta	O sistema nunca suspende sozinho: alertas só sinalizam e limitam o envio; quem suspende é uma pessoa, com motivo. Alerta descartado remove a restrição, a conta é reativável e o usuário é avisado com o motivo. Prazo de contestação e tratamento jurídico (LGPD, art. 20) pendentes.
R35	O endpoint público de coleta ser usado para poluir os dados ou sobrecarregar o servidor.	Média	Baixo	Baixa	Lote de até 50 eventos, limite por origem, validação e normalização de cada campo, hora e papel definidos pelo servidor, descarte silencioso do inválido. O limite é em memória (uma instância); distribuído na V2.
R36	Injeção de fórmula em planilha por um alvo de clique manipulado na exportação CSV.	Baixa	Médio	Baixa	O alvo só aceita caracteres estruturais, nunca começa por =, +, - ou @, e a exportação escapa vírgulas e aspas.
R37	Permitir enquadramento em iframe (necessário ao mapa de calor) abrir espaço para clickjacking.	Baixa	Médio	Baixa	A política passou a permitir apenas a própria origem (frame-ancestors 'self' e SAMEORIGIN); nenhum outro site consegue emoldurar; o iframe do mapa não aceita interação e o teste de cabeçalhos foi atualizado.
R38	A tabela de eventos de uso crescer além do que o banco transacional comporta.	Média	Médio	Média	Retenção diária, índices só para as consultas do painel, agregação no banco, exportação em lotes por chave. Rollup e particionamento mensal ficam para a V2.

Fonte: elaborado pelos autores (2026).

Os riscos R04, R07, R08, R11, R32 e R34 concentram a maior severidade combinada. Recomenda-se revisão semanal deste documento pela equipe, com o registro explícito de qualquer risco novo identificado ao longo do desenvolvimento.